

DESIGNING A SECURE, MULTI-ENTITY AWS S3 GLACIER LOG ARCHIVE WITH IDENTITY AND ACCESS MANAGEMENT BASED SEGMENTATION AND CENTRALIZED SECURITY MONITORING.

SALIM AHMED ABDULLAHI (MS CYBERSECURITY AND NETWORKS)

UNIVERSITY OF NEW HAVEN.

1. HIGH LEVEL ARCHITECTURE

ABC's logging architecture centralizes security logs from 10 entities into google sec-ops for detection and analysis, then routes these logs through cribl into a secure AWS S3 based archival system with lifecycle transitions into S3 glacier for long term storage. ABC uses a centralized AWS log archive account to store all security logs while enforcing strict logical isolation using Identity and Access Management policies, S3 prefixes, and encryption controls.

2. S3 GLACIER STORAGE ARCHITECTURE.

In this project, I will be designing one S3 bucket for all 10 entities instead of each entity to have each's own bucket. Why just one bucket? One bucket is designed for easier lifecycle management and is easier when it comes to auditing. Each entity's log data is logically isolated using a dedicated S3 prefix, ensuring that lifecycle management and access control can be enforced.

2.1 ROLE OF CRIBL

Cribl acts as the log routing and enrichment layer. It inspects incoming log events, tags them with entity identifiers, and forwards them to the appropriate S3 prefix. Cribl does not enforce access control itself, instead, it ensures logs are delivered to the correct logical location where AWS services enforce security policies.

2.2 S3 BUCKET DESIGN

ABC stores all security logs in a centralized S3 bucket named abc-security-log-archive-prod

BUCKET BREAKDOWN

Abc: Company name

security-log: purpose of the bucket

archive: long-term storage

prod: production environment.

2.3 S3 PREFIX STRUCTURE

abc-security-log-archive-prod/

└─ entity=1/

└─ entity=2/

└─ entity=3/

└─ ...
└─ entity=10/

The reason why the above S3 prefix is powerful and secure is that, Entity 4 and the users in that entity can only have access to the entity 4 folder. Any other entity apart from entity 4 can not have access to the entity 4. Central security is the only privileged internal team (users) that can have access to all entities.

3. LIFECYCLE RULES

ABC leverages S3 lifecycle policies to automatically transition security logs through multiple storage classes based on age. Newly ingested logs remain in S3 Standard for active investigation, transition into S3 Standard IA for reduced access periods, and are later archived into S3 glacier and glacier deep archive for long term, cost efficient retention. All security logs are initially stored in Amazon S3 standard under entity specific prefixes.

An S3 lifecycle policy named security-log-achive-lifecycle applies to all prefixes (entity=*) and automatically transitions objects as follows:

After 90 days- S3 standard IA

After 90 days- S3 Glacier Flexible Retrieval

After 365 days- S3 Glacier Deep Archive

Logs are retained for up to 7 years in accordance with compliance requirements.

3.1 HOW GLACIER FITS INTO THE WORKFLOW

Amazon S3 Glacier is integrated into the logging workflow through S3 lifecycle policies rather than direct ingestion. Logs are initially written to Amazon S3 by Cribl for active analysis and operational access. As log ages, lifecycle policies automatically transition them into S3 glacier and glacier deep archive for long term retention.

4. SEGEMENTATION STRATEGIES.

Log data isolation is enforced through multiple security layers. Each entity's logs are stored under dedicated S3 prefix and tagged with an entity identifier at ingestion. IAM policies use conditional logic to restrict entity roles to objects matching both the assigned prefix and entity tag. S3 bucket policies provide an additional enforcement layer by denying cross-entity access and preventing unauthorized deletion of log data. This defense-in-depth approach ensures strict data segregation while enabling security visibility..

4.1 SEGMENTATION STRATEGY

Bucket: abc-security-log-archive-prod

Prefix: entity=4/year=2025/month=12/day=18/

OBJECT PATH: S3://abc-security-log-archive-prod/entity=4/year=2025/month=12/day=18/vpn.log

The above prefix means the log belongs to entity 4, stored on 12/08/2025.

The vpn.log is the name of the log. It just specifies where the log was coming from and in this case, it was from a vpn.

Below is a tag.

```
entity_id = 4
```

```
environment = prod
```

```
log_source = vpn
```

Cribl applies these tags at ingestion to reinforce ownership and support IAM based access controls.

5. IAM ROLE AND POLICY MODEL

ABC enforces least-privilege access through three IAM role types:

1. Cribl ingestion role with write-only permissions to entity prefixes and required tagging.
2. Per-entity read-only rules constrained by both prefix and object tag conditions.
3. Central Security read-only role authorized across all entity prefixes.

All logs are encrypted using SSE-KMS(Security Token Service-Key Management System), with either a shared customer-managed Key(CMK) for simplicity or per-entity CMK's for stronger cryptographic isolation. CloudTrail auditing and bucket policy guardrails further prevent cross-entity access and unauthorized modification.

5.1 CRIBL INGESTION ROLE

Cribl functions as the log routing and enrichment layer, inspecting incoming events, assigning entity-specific prefixes and tags, and forwarding logs to Amazon S3, where AWS services enforce encryption, access control, and lifecycle management.

5.1.1 EXAMPLE OF CRIBL IAM POLICY (WRITE ONLY)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AllowCriblToWriteEntity4Logs",
      "Effect": "Allow",
      "Action": [
        "S3:PutObject",
        "S3:PutObjectTagging"
      ],
    }
  ],
}
```

```

    "Resource": "arn:AWS:S3:::abc-security-log-archive-prod/entity=4/*"
  }
]
}

```

5.1.2 POLICY EXPLANATION

S3:PutObject: Allows Cribl to upload log files

S3:PutObjectTagging: Allows cribl to apply tags

The resource restriction ensures cribl can only write to the correct entity prefix.

5.2 PER ENTITY READ-ONLY ROLE.

Each entity is assigned read-only IAM role (example, ABC-Entity-LogReadRole) that permits access only to log objects stored under its corresponding S3 prefix. Access is further restricted using object tags that identify the owning entity.

All write, and configuration permissions are explicitly denied to enforce least privilege and preserve log integrity.

5.3 CENTRAL SECURITY ROLE.

ABC's Central Security Team uses a dedicated IAM role with read-only access across all entity prefixes to support incident response, threat hunting, and compliance investigations. The role permits listing and retrieving log objects across Entities 1–10 while explicitly denying write, delete, and configuration actions. Because logs are encrypted with SSE-KMS,(Server Side Encryption-Key Management System), the Central Security role is granted KMS decrypt permissions for the shared key (or all per-entity keys). All access is continuously audited with CloudTrail and protected with strong authentication controls such as SSO (Single Sign On) and MFA (Multi-factor Authentication).

6. KEY MANAGEMENT SYSTEM

All log data stored in Amazon S3 is encrypted at rest using Server-Side Encryption with AWS KMS (SSE-KMS). ABC may use either a shared KMS customer-managed key for simplicity or per-entity keys to provide stronger cryptographic isolation. Cribl is granted permission to encrypt log objects at ingestion, while entity roles are permitted to decrypt only the keys associated with their authorized log data. The Central Security role is granted decrypt access across all keys to support investigations and compliance activities. This dual-control model ensures that both storage access and cryptographic permissions are required to access sensitive log data

7. NETWORK LEVEL CONTROLS(VPC)

Cribl is deployed inside a dedicated VPC(Virtual Private Cloud) using private subnets across multiple Availability Zones to prevent direct internet exposure. To avoid public internet paths, the architecture uses VPC endpoints

1. An S3 gateway endpoint for private log delivery to S3
2. KMS and STS interface endpoints for encryption and authentication.

Cribl authenticates using IAM role with short-lived STS credentials rather than long lived access keys, enabling secure and automatically rotating access. Bucket policies and security groups provide additional guardrail by restricting access to approved network paths and enforcing least- privilege connectivity.

8. COMPLIANCE AND AUDIT STRATEGY

ABC implements a comprehensive compliance and audit strategy to protect the integrity of archived log data. AWS CloudTrail is enabled to capture all management and data access activity, ensuring complete visibility into log ingestion, access, and configuration changes. Access logging provides additional insight into which log objects are accessed and by whom. To prevent tampering, S3 Object Lock enforces write-once, read-many (WORM) retention, ensuring logs cannot be modified or deleted before the retention period expires. Additional guardrails, including restrictive bucket policies, least-privilege IAM roles, KMS encryption controls, and separation of duties, collectively ensure the confidentiality, integrity, and auditability of all security logs.